

W12D4 - Analisi delle vulnerabilità e azioni di rimedio

Azioni di remediation

Ignazio Guttadauro

Dopo la scansione iniziale sono intervenuto sulle tre vulnerabilità Critical selezionate. Per ogni modifica ho eseguito anche un controllo manuale per verificare che il problema fosse stato effettivamente corretto.

1. Remediation della password VNC

Per correggere il problema VNC ho controllato quale file delle password veniva realmente utilizzato dal processo Xtightvnc. Il servizio sulla porta 5900 utilizzava /root/.vnc/passwd. Ho quindi cambiato la password con vncpasswd impostandone una più robusta. La nuova password non viene riportata nel report.

```
Last login: Sun Oct 4 07:52:39 2020
msfadmin@metasploitable:~$ sudo cat /proc/4554/cmdline | tr '\0' ' '
[sudo] password for msfadmin:
XtightVNC -D -desktop X -auth /root/.xauthority -geometry 1024x768 -depth 24 -fbwait 120000 -fbauth /root/.vnc/passwd -fbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fonts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/share/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co /etc/X11/rgb -msfadmin@metasploitable:~$ sudo vncpasswd
/root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$
```

Figura 1 - Aggiornamento della password utilizzata dal servizio VNC.

Dopo la modifica ho provato a collegarmi da Kali con vncviewer. Con la vecchia password "password" ho ricevuto Authentication failure. Ripetendo il collegamento con la nuova password l'autenticazione è riuscita, quindi la vecchia credenziale non era più valida e il servizio continuava a funzionare.

```
(kali@kali)-[~]
$ which vncviewer
/usr/bin/vncviewer

(kali@kali)-[~]
$ vncviewer 192.168.50.101:0
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password: is not known by any other names.
Authentication failure
Warning: Permanently added '192.168.50.101' (RSA) to the list of known hosts
(kali@kali)-[~]
$
```

Figura 2 - La vecchia password VNC viene rifiutata.

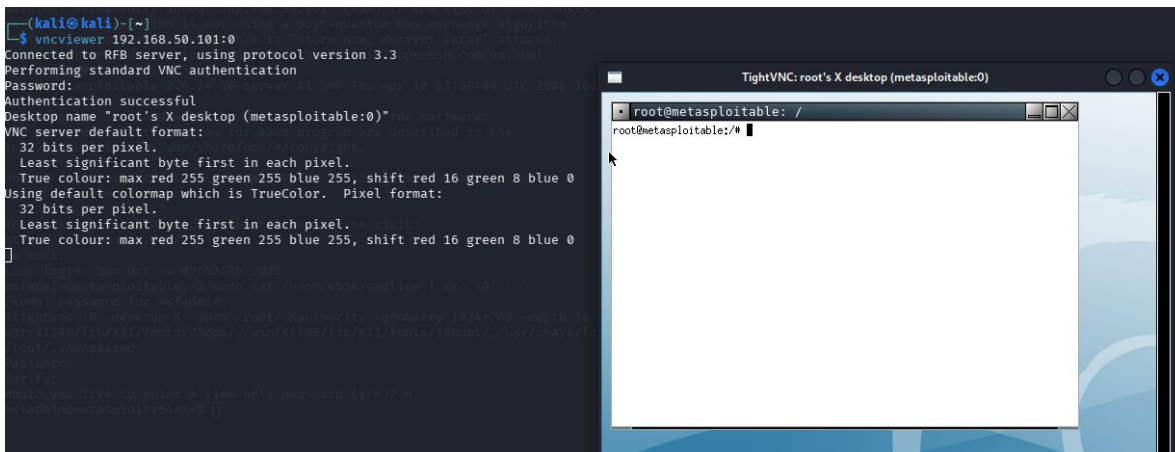


Figura 3 - Autenticazione riuscita con la nuova password.

2. Remediation della Bind Shell sulla porta 1524

Per capire da dove proveniva la shell sulla porta 1524 ho cercato la relativa configurazione nel sistema. Nel file `/etc/inetd.conf` ho trovato la voce `ingreslock` configurata per avviare `/bin/bash` come `root`. Prima di modificarla ho creato una copia di backup del file, poi ho commentato la riga e riavviato `xinetd`.

```
msfadmin@metasploitable:~$ sudo grep -R "ingreslock\|1524" /etc 2>/dev/null
/etc/services:ingreslock      1524/tcp
/etc/services:ingreslock      1524/udp
/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

Figura 4 - Configurazione ingreslock che avviava /bin/bash come root.

```
msfadmin@metasploitable:~$ sudo cp /etc/inetd.conf /etc/inetd.conf.bak
msfadmin@metasploitable:~$ sudo sed -i '/^ingreslock /s/^/#/' /etc/inetd.conf
msfadmin@metasploitable:~$ grep ingreslock /etc/inetd.conf
#ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

Figura 5 - Disabilitazione della voce ingreslock.

Dopo il riavvio ho controllato nuovamente la porta 1524 e non risultava più in ascolto. Ho fatto anche una prova da Kali con `netcat` e la connessione è stata rifiutata. La bind shell quindi non era più raggiungibile dalla rete.

```
Session  Actions  Edit  View  Help
(kali@kali)-[~]
$ nc -nv 192.168.50.101 1524
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection refused
msfadmin@metasploitable:~$
(kali@kali)-[~]
$
```

Figura 6 - Verifica da Kali: connessione alla porta 1524 rifiutata.

3. Remediation Ghostcat / AJP 8009

Per Ghostcat ho verificato la configurazione di Tomcat e ho trovato il connettore AJP/1.3 attivo sulla porta 8009 nel file `/etc/tomcat5.5/server.xml`. Poiché nel laboratorio non avevo bisogno del connettore, ho creato un backup del file, commentato il Connector relativo alla porta 8009 e riavviato Tomcat 5.5.

```
msfadmin@metasploitable:~$ sudo grep -n -B 2 -A 3 '8009' /etc/tomcat5.5/server.xml
102-   →
103-
104-   <!-- Define an AJP 1.3 Connector on port 8009 -->
105-   <Connector port="8009"
106-       enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
107-
108-   <!-- Define a Proxyied HTTP/1.1 Connector on port 8082 -->
msfadmin@metasploitable:~$
```

Figura 7 - Connettore AJP/1.3 attivo sulla porta 8009.

```
msfadmin@metasploitable:~$ sudo sed -n '102,109p' /etc/tomcat5.5/server.xml
→
   <!-- Define an AJP 1.3 Connector on port 8009 -->
<!--   <Connector port="8009"
       enableLookups="false" redirectPort="8443" protocol="AJP/1.3" /> -->

   <!-- Define a Proxyied HTTP/1.1 Connector on port 8082 -->
   <!-- See proxy documentation for more information about using this. -->
msfadmin@metasploitable:~$
```

Figura 8 - Connettore AJP disabilitato nel file `server.xml`.

Dopo il riavvio ho controllato che la porta 8009 non fosse più in ascolto. Ho effettuato anche un test da Kali con netcat e il risultato è stato Connection refused. Il connettore AJP quindi non era più esposto sulla rete.

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]─┐
$ nc -nv 192.168.50.101 8009
(UNKNOWN) [192.168.50.101] 8009 (?): Connection refused
msfadmin@metasploitable:~$ sudo cp /etc/inetd.conf /etc/inetd.conf.bak
┌──(kali㉿kali)-[~]─┐
$ sudo sed -i 's/^#Ingreslock /s/^?#/' /etc/inetd
#Ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$ grep Ingreslock /etc/inetd
msfadmin@metasploitable:~$ sudo /etc/init.d/openbsd-inetd restart
```

Figura 9 - Verifica da Kali: connessione alla porta 8009 rifiutata.